Cheatsheet AZ-305 — 05 · OAuth, identidades de aplicación, Key Vault y API Management

1. Roles en OAuth 2.0 con Microsoft Entra ID

Rol	Quién	Qué hace
Authorization Server	Microsoft Entra ID (o B2C)	**Autentica, pide consentimiento y emite/firma los tokens**
Client	La app que llama (web app, SPA, servicio)	Solicita el token y lo envía en Authorization: Bearer
Resource Server	La API	**Valida** el token (firma, aud , expiración, claims) y decide la **autorización**
Resource Owner	El usuario	Da consentimiento

- "Access tokens generated by" → **Entra ID**. "Authorization decisions performed by" → **la Web API**.
- Key Vault nunca emite tokens de OAuth.

2. Grant types

Grant	¿Usuario?	Secreto de cliente	Uso	Estado
Authorization Code (+PKCE)	Sí	Sí (PKCE si no puede guardarlo)	Web apps, móviles, SPAs	✓ Recomendado
Client Credentials	**No**	Sí (secreto / certificado)	App-a-app, jobs, backends, managed identities	✓ Para M2M
Implicit	Sí	No	(Legacy) SPAs	✗ Deprecado
Resource Owner Password	Sí (la app ve la contraseña)	Sí	(Legacy) migraciones	✗ Evitar; incompatible con MFA
Device Code	Sí	No	Dispositivos sin navegador	Nicho

- **state parameter:** valor opaco que va y vuelve en la redirección; protección CSRF y **transporte de datos propios ("custom data") de la app**. Solo tiene sentido con redirección (Auth Code / Implicit).

3. Delegated vs Application permissions

	Delegated	Application
Actúa en nombre de	**Un usuario** con sesión	**La app** (sin usuario)
Flujo	Authorization Code	Client Credentials / Managed Identity
Consentimiento	Usuario o admin	**Siempre admin consent**
Claim en el token	scp (scopes)	roles (app roles)
Alcance efectivo	Lo que el usuario puede hacer	Todo lo concedido, en toda la organización
Se define en la API como	Scope (Expose an API)	App role (App roles, member type Applications)

4. App registration: qué blade toca cada app

Necesidad	App	Blade
Exponer permisos/roles a otras apps	La **API**	**Expose an API** (scopes) / **App roles**
Solicitar permisos/roles de otra API (que aparezcan en el token)	El **cliente**	**API permissions** (+ admin consent)
Añadir claims opcionales al token	Cualquiera	Token configuration
Registrar una app para autenticación Entra ID	La app	App registration (base de todo)
Publicar app on-prem con SSO sin VPN	—	Application Proxy + Enterprise Application (KCD para Kerberos)
App registration vs Enterprise application	Registration = definición (una); Enterprise app = instancia/service principal en el tenant (permite asignar usuarios, CA, SSO SAML)	

- SSO silencioso en dispositivos **Entra-joined** → app registration + **PRT** del dispositivo; no hace falta nada más.
- Acceso solo desde equipos de empresa → Conditional Access · Grant · compliant / joined device.

5. Identidades para aplicaciones

Identidad	Dónde corre la app	Credenciales	Cuándo
Managed identity (system / user-assigned)	**Solo recursos de Azure** (VM, App Service, Functions, AKS, Policy remediation, Data Factory)	Ninguna que gestionar	Siempre que la app esté en Azure
Service principal	Cualquier sitio (on-prem, otra nube, CI/CD)	Secreto o certificado	App fuera de Azure; rotación de personal
Personal access token / usuario	—	Ligado a una persona	Evitar (staff turnover)

Identidad	Dónde corre la app	Credenciales	Cuándo
Certificado en Key Vault	Apps que necesitan mTLS o firma	Certificado gestionado	Autenticación de app con cert

- **IMDS** (169.254.169.254/metadata/identity/oauth2/token): endpoint local con el que una **VM** obtiene el token de su managed identity. "Which endpoint to obtain an access token" con managed identity → IMDS.
- **User-assigned** MI: reutilizable en varios recursos, vida independiente. **System-assigned**: nace y muere con el recurso.

6. Key Vault: tres objetos

Objeto	Qué es	Operación	Ejemplos
Secret	Texto sensible que se recupera tal cual	GET secret	Connection strings, contraseñas, API keys
Key	Clave criptográfica (RSA/EC) que **nunca sale**	encrypt / decrypt / sign / wrap	CMK para Storage / SQL TDE / ADE, firma
Certificate	Certificado X.509 con su clave y renovación	GET certificate , auto-renew	TLS, mTLS, firma de apps

- **SKU Standard** (software) vs **Premium** (**HSM-backed keys, FIPS 140-2 Level 2**) vs **Managed HSM** (Level 3, single-tenant).
- Acceso: **RBAC** (recomendado) o access policies; **managed identity** de la app como llamante; **Private Endpoint** para acceso privado.
- "Protect connection strings, only the app at runtime, no hard-coded credentials" → **Key Vault** (el almacén), con managed identity como mecanismo de acceso.

7. Cifrado: dónde está cada tecnología

Estado	Tecnología
En reposo	SSE (Storage, PMK/CMK), **TDE** (SQL, archivos), **Azure Disk Encryption** (BitLocker/DM-Crypt + Key Vault del cliente, auditable), Always Encrypted (columnas; solo el cliente descifra)
En tránsito	TLS/HTTPS, IPsec (VPN), MACsec (ExpressRoute Direct)
En uso	**Azure Confidential Computing** (TEE, Confidential VMs)
Enmascarar por rol	**Dynamic Data Masking** (unos ven todo, otros los últimos 4 dígitos)

- mTLS en App Service: el certificado de cliente llega en la cabecera **X-ARR-ClientCert** .
- VPN P2S con certificados: sube a Azure la **clave pública del root**; los certificados de cliente se quedan en los dispositivos; revocación individual por thumbprint.

8. API Management

Concepto	Qué es
Products	Empaquetado de APIs para consumidores: suscripciones, quotas, términos
Policies	XML en inbound / backend / outbound / on-error: validate-jwt , rate-limit , quota , set-header , ip-filter , cors , validate-client-certificate , transformación XML↔JSON
Modos de VNet	**External**: gateway con IP pública + backends privados · **Internal**: todo privado · **None**: sin VNet
Tiers	Consumption (serverless) · Developer (no producción) · Basic · Standard · **Premium** (VNet inject, multi-región, ISE-like) · v2 tiers (Basic v2, Standard v2 con VNet integration saliente)
VNet injection (External/Internal)	Solo **Developer y Premium** (clásicos)
Self-hosted gateway	Gateway de APIM desplegado on-prem / otras nubes

- "third-party OAuth provider" + "rate limits distintos por consumidor" + "no changes to backend" + "no guest accounts" → **APIM** (validate-jwt + Products).
- "remove AspNet-Version header" → **policy** (set-header delete).
- "private IP + mTLS + rate limiting" (opciones APIM) → **Premium Internal** (respuesta del examen; Standard no inyecta en VNet).
- Cadena Front Door → APIM → backend: **OWASP → Front Door; JWT/ratelimit/products → APIM; IP filtering per-API → APIM** (en matching, B2C recibe "JWT").
- HTTP trigger de Functions: **Anonymous** (público) · **Function** (key para apps de confianza) · **Admin** (master key). Read-only → **GET only**; CORS lo gestiona la plataforma (no añadir OPTIONS).

9. Árbol de decisión (identidad de app)

```
¿Dónde corre la app?
├─ En Azure ............................ Managed identity (token vía IMDS en VMs)
├─ Fuera de Azure ...................... Service principal (secreto/certificado en Key Vault)
└─ ¿Actúa por un usuario?
     ├─ Sí → Authorization Code, delegated permissions (scp)
     └─ No → Client Credentials, application permissions (roles), admin consent
```

10. Señales → respuesta

Enunciado	Respuesta
"tokens generated by"	Microsoft Entra ID
"authorization decisions by"	La Web API
"custom data in the grant flow"	Support state parameter
"token must include the Writer role of App1" (modificar App2)	API permissions de App2
"grant permissions using Entra-generated claims"	Microsoft Entra ID
"JWT validation policy using"	Azure API Management
"no user interaction", "service to service"	Client Credentials / application permission
"obtain access token" + managed identity en VM	IMDS
"on-premises app" + "staff turnover"	Service principal
"retrieve keys for use in code" (Development team)	Managed identity
"connection strings", "runtime only"	Key Vault (secrets)
"FIPS 140-2 Level 2 HSM"	Key Vault Premium
"verify client certificate in web app"	HTTP request header
"data in use"	Confidential Computing
"supervisors see full number, operators last 4 digits"	Dynamic Data Masking
"never in plain text in the DB, only client decrypts"	Always Encrypted

11. Errores a evitar

1. Managed identity para una app on-prem → no existe fuera de Azure.
2. Managed identity como "almacén" de secretos → es el mecanismo de acceso; el almacén es Key Vault.
3. Confundir app registration (definición) con enterprise application (instancia).
4. Implicit o ROPC como flujo "recomendado".
5. Modificar App roles en la app cliente → se modifica API permissions.
6. APIM Standard para IP privada → no inyecta en VNet.